

[doc. web n. 10139489]  
Provision of March 27, 2025  
Register of provisions  
n. 170 of March 27, 2025

## THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by  
Prof. Pasquale Stanzione, President, Prof.  
Ginevra Cerrina Feroni, Vice President, Dr.  
Agostino Ghiglia and Attorney Guido Scorza, members, and  
Secretary General Fabio Mattei;

HAVING REGARD to Regulation (EU) 2016/679 of the European  
Parliament and of the Council, of April 27, 2016, concerning  
the protection of natural persons with regard to the  
processing of personal data, as well as the free  
movement of such data and repealing Directive  
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing  
"Code regarding the protection of personal data,  
containing provisions for the adaptation  
of the national legal system to Regulation (EU)  
2016/679 of the European Parliament and of the Council, of  
April 27, 2016, concerning the protection of  
natural persons with regard to the processing of personal data,  
as well as the free movement of such data and repealing Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD to Regulation No. 1/2019 concerning  
internal procedures with external relevance,  
aimed at carrying out the tasks and  
exercising the powers entrusted to the Guarantor for the  
protection of personal data, approved by  
resolution No. 98 of April 4, 2019, published  
in G.U. No. 106 of May 8, 2019 and on [www.gpdp.it](http://www.gpdp.it),  
doc. web n. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Secretary  
General pursuant to Article 15 of the Guarantor Regulation  
No. 1/2000 on the organization and functioning of the  
office of the Guarantor for the protection of personal data, on [www.gpdp.it](http://www.gpdp.it), doc.  
web n. 1098801;

REPORTING Attorney Guido Scorza;

## PREMISED

1. The complaint  
With a complaint submitted on XX, Ms. XX has  
complained of having made, to the  
Territorial Health Authority of Macerata (hereinafter "Authority"), on  
XX and XX, requests for  
access to personal data, pursuant to Article 15 of the  
Regulation, without receiving any response in  
this regard.

In response to the invitation from the Office, which invited the aforementioned Authority to comply with the requests of the complainant pursuant to Article 15 of Regulation No. 1/2019 (note of X, prot. n. XX), it provided feedback to the interested party and, for information, to the Authority, stating, among other things, that:

- "(...) having the radiology staff requested a completion/deepening, the Oncology Screening Unit attempted to reach her at her mobile number without receiving a response. It is specified that her mobile number is registered both in the "health registry" (ARCA database) and in the screening management software (called project SCOPRE). In the ARCA database, (...) her personal/common data can be found, such as name, surname, Tax Code, date of birth, gender, general practitioner, domicile, residence, and mobile number. Furthermore, in the same registry, the patient is linked to their family unit, which must be updated/corrected by the patient. This is because some data, such as residence, are automatically updated through the TS system (health card), while others, such as the composition of the family unit for health purposes, remain unchanged if the user does not provide communication. As you can see from the attached (...) her personal and contact data are linked with (...) (father) and (...) (mother) (of the complainant)."

Following this feedback, the complainant, with communication dated XX, made observations to the Authority and the Authority, also highlighting the alleged unlawful processing carried out by the Authority for having communicated to her mother the need for the complainant to undergo further diagnostic assessments compared to those already performed. In particular, the complainant stated, among other things, that: "(...) it is objected that the above was communicated to a third party without first obtaining the consent of the interested party to use the contact data of family members for such communications. It is not disputed that my parents' data are linked to my registration file, acquired through the regional health registry, but the failure to obtain the consent of the interested party for the use of the same for the aforementioned purposes. The good intentions of the AST, which are certainly not subject to discussion, cannot justify such unlawful processing. (...) Only one attempt was made to contact me by phone.

Following my lack of response, I contacted (the Authority) by phone after just a few minutes, and the operator informed me that she had already contacted my mother and had explained to her what was determined by the radiologist" (note of XX, prot. n. XX).

## 2. The investigative activity

Following the Authority's request for information

(note of XX, prot. n. XX), the Authority declared, among other things, that:

- "what occurred during the contact of Ms. XX by the Oncology Screening service represents a mere human error, despite this

Authority (through the suppressed Regional Health Authority — ASUR, L.R. Marche August 8, 2022, n. 19) had prepared specific organizational measures — in particular, written operational instructions — specific to the area of operators responsible for booking and contacting patients for the second-level screening;

- "attached, in this regard, are the operational guidelines approved in 2021 — (...) (where on page 3 it states that "the SSO/(oncological screening service) calls women by phone to carry out the second level") as well as the draft of the new operational guidelines currently under approval — (...) (on page 7 where it states that "The SSO calls women by phone to carry out the second level, enters the appointment into the Screening program which also sends the appointment to e-Ris. Regarding calls to schedule second-level appointments, the following procedure is followed: only the directly interested party is called, ensuring that the number from the regional screening software or the regional health registry belongs to the user; no communication is left with other people; if the user answers, the booking proceeds; if the user does not answer, a total of 3 attempts are made (two on the same day and the 3rd on the following day); if the user is ultimately unreachable, a letter of UNREACHABILITY is sent both as a registered letter and by ordinary mail")";

- "also following the first request for information from this Authority of XX, the oncological screening service convened a meeting (the minutes of which are attached — annex 3) in which the Responsible Manager reiterated to the staff responsible for booking and contacting patients for the second-level screening, what was already contained in the existing operational guidelines (annex 1) and what is contained in the new operational guidelines currently under approval (...);

- "the Company then, in the annual planning related to staff training, has provided for employees of the U.O. Oncological Screening Improvement Groups in the type of field training - in order to update and improve the procedures for managing the second level of screening in light of the software program "Scope"; training dates XX — XX — XX as per DG Determination (...);

- "the Data Controller (AST Macerata) has implemented adequate organizational and technical measures, specific instructions provided to the staff belonging to the oncological screening service, in order to ensure adequate security in the processing of personal data (in this case, sensitive data), in compliance with European and national provisions and the principle of privacy by design. It is clear that the technical and organizational measures put in place have served, and still serve, to mitigate the risk of non-compliant processing, not to eliminate it outright: the employee assigned to call the patient for the booking of a second-level screening was aware of the standardized procedure to be used, which has been in place for years. However, the same, making an error in judgment, deemed it quite urgent to immediately communicate the necessity for the interested party XX to undergo a second-level check-up not to just anyone, but to the mother (who from the company systems appears to be cohabiting) of the interested party";

- "(...) it is emphasized that AST Macerata was established by DGRM no. 1502/2022 (...). Prior to that (until 31.12.2022), in place of AST Macerata (and the other 4 AA.SS.TT.), the Data Controller was the abolished Regional Health Authority (ASUR). (...) Pending the definition of the new organizational structure, efforts are being made to update the regulations regarding personal data protection, customizing it according to the company's specificities (...)" (note from XX, prot. no. XX).

In relation to what has been communicated, the Office, with act of XX, prot. no. XX, initiated, pursuant to Article 166, paragraph 5, of the Code, a procedure for the adoption of the measures referred to in Article 58, paragraph 2 of the Regulation, against the Company inviting it to produce to the Guarantor defensive writings or documents or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code, as well as Article 18, paragraph 1, law no. 689 of November 24, 1981). Following what emerged, in fact, the Office deemed that the Company, as the data controller, in the matter in question:

- a) had processed certain health-related data of the complainant in violation of the principle of “integrity and confidentiality” of personal data and the security obligations related to processing, in violation of Articles 5, paragraph 1, letter f) and 32 of the Regulation;
- b) had communicated health-related data of the complainant to a third party (the mother) in the absence of a legitimate legal basis, in violation of Article 9 of the Regulation;
- c) had not provided feedback to the request for the exercise of rights submitted by the interested party within the terms of Article 12 of the Regulation (Article 12 of the Regulation in relation to Article 15 of the same Regulation).

With a note sent via certified email on XX, the Company submitted its defensive memoranda, in which it again highlighted that:

“even in the 2021 guidelines, (Annex no. 1 to the note of 10/10/2024) there is a specific instruction for the employee of the oncological screening service: “Call women by phone to carry out the second level”;

“the technical and organizational measures put in place have served, and still serve, to mitigate the risk of non-compliant processing, not to eliminate it outright. The employee assigned to call the patient for the booking of a second-level screening was aware of the standardized procedure to be used, put in place for years.

**\*\*Field for years\*\***;

**\*\*\***“however, it was deemed quite urgent to immediately communicate the necessity for the interested party XX to undergo a level II check-up to her mother, considering, at that moment, the right to health of the aforementioned as paramount in light of a suspicious diagnosis.”**\*\*\***

On XX, a hearing was held via remote videoconference, during which the Company supplemented its defense statements, declaring that:

**\*\*\***“the reasons for the incident are based on the need to urgently ensure the best care for the interested party, as a follow-up examination of the screening mammography became necessary, as provided for by the regional medical protocol for such cases. The contact with the third party regarding the interested party thus occurred in good faith, due to an excess of zeal on the part of the operator, considering that the clinical situation of the patient presented profiles of particular criticality and severity. Moreover, the operator did not provide any clinical information to the third party contacted, but only communicated an additional appointment at the U.O.C. of Radiology.”**\*\*\***

**\*\*\***“What occurred has led to the improvement of the ongoing procedure, through a more precise and detailed reformulation of the guidelines to be followed by the operators responsible for calling for level II checks.”**\*\*\***

**\*\*\***“Regarding the lack of response to the exercise of rights, it is specified that the complainant shares the same name as an employee of the health company (specifically from the U.O.S.D. that manages cancer screening), and therefore, the protocol service operators deemed it appropriate to transmit the documentation solely to the Personnel Office - which deals with approximately four thousand employees - and not to the Office responsible for managing such requests.”**\*\*\***

**\*\*\***“The complainant has continued to receive the care provided by our health company, which has delivered such care in compliance with the protocol, ensuring her follow-up screening pathway.”**\*\*\***

### **\*\*3. Outcome of the investigative activity\*\***

Taking note of what was represented by the Company, it is observed that:

1. For “personal data,” it is understood as “any information relating to an identified or identifiable natural person (‘data subject’)” and for “data concerning health,” it is understood as “personal data related to the physical or mental health of a natural person, including the provision of health care, which reveals information about their health status” (art. 4, par. 1, n. 1 and 15 of the Regulation). The latter data deserves greater protection since the context of their processing could create significant risks to the rights and fundamental freedoms (Recital no. 51);
2. The data controller is required to comply with the principles regarding data protection, including the principle of “integrity and confidentiality,” according to which personal data must be “processed in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage” (art. 5, par. 1, lett. f) of the Regulation).

The adequacy of such measures must be assessed by the data controller in order to “ensure a level of security appropriate to the risk,” taking into account, among other things, “the nature, scope, context and purposes of the processing, as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons” (art. 32 of the Regulation);

3. Regarding information, communication, and transparent modalities for the exercise of the rights of the data subject, art. 12, par. 3, of the Regulation establishes that the data controller must respond to the request of the data subject, made pursuant to arts. 15 to 22 of the Regulation, without undue delay and, in any case, no later than one month from receipt of the same. This period may be extended by two months, if necessary, taking into account the complexity and number of requests, provided that the data subject is informed of such extension and the reasons for the delay within one month of receiving the request. If the data controller does not comply with the request of the data subject, they must, in any case, inform the data subject without delay and, at the latest, within one month from receipt of the request, of the reasons for non-compliance and the possibility of lodging a complaint with a supervisory authority and seeking judicial remedy (cons. 59 and art. 12, par. 4, of the Regulation). In the case of a request made pursuant to art. 15 of the Regulation, the data subject has the right to ask the data controller and obtain within the aforementioned terms, if the conditions are met, confirmation as to whether or not personal data concerning them is being processed, as well as access to personal data and the information referred to in par. 1 (letters a) to h)) and 2 of the same article 15;

4. The regulation on personal data protection provides that information on health status may only be communicated to the data subject and may be communicated to third parties only on the basis of an appropriate legal basis or at the request of the data subject itself, upon prior written delegation from the latter (art. 9 of the Regulation).

#### **\*\*4. Conclusions.\*\***

In light of the evaluations mentioned above, taking into account the statements made by the data controller...

treatment during the investigation and considering that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor." The elements provided by the data controller in the aforementioned defense memorandum, although deserving of consideration, do not allow for overcoming the observations notified by the Office with the referenced initiation act of the proceedings, nor do any of the cases provided for in Article 11 of the Guarantor's Regulation No. 1/2019 apply.

4.1. Failure to comply with the basic principles of processing (Article 5, paragraph 1, letter f) and 9 of the Regulation) and security obligations related to processing (Article 32 of the Regulation)

First of all, regarding the existence of technical and organizational measures for managing second-level screenings in compliance with personal data regulations, from the elements acquired during the investigative activity, it appears that the Company, at the time of the event that occurred, had not adopted measures, technical and organizational, adequate to prevent the event, in violation of the security obligations referred to in Article 32 of the Regulation. In fact, although the health company, with reference to the document "Operational Guidelines for the Management of Mammograms and First and Second Level Mammographic Screening Exams" dated XX, attached to the response provided to the Authority, stated that "the employee in charge of calling the patient for the booking of a second-level screening was aware of the standardized procedure to be used, implemented for years (and) (...) (made) an error of judgment (...)", only in the new "Operational Guidelines under approval" did it provide that "(...) to schedule second-level appointments (...) only the directly interested party is called (...) (and) no communication is left to other people," also planning training events for staff as organizational measures to prevent similar events from occurring in the future (see response note to the request for information dated XX).

Furthermore, the Company, having communicated to the mother of the interested party - in the absence of a legitimate legal basis - the necessity for the latter to undergo further diagnostic checks, compared to those already performed, acted in violation of Article 9 of the Regulation. In this regard, it

is highlighted that human error is "a symptom of negligence" (see in this sense the document "Guidelines regarding the application and prediction of administrative monetary sanctions for the purposes of Regulation (EU) No. 2016/679" - Adopted on October 3, 2017 - WP 253 - Chapter III "Evaluation Criteria pursuant to Article 83, paragraph 2", paragraph b) "Intentional or negligent nature of the violation") which, although unintentional, can be avoided through adequate and effective measures to comply with diligence obligations.

#### 4.2. Late response to the request for access to data (Article 12 of the Regulation)

As for the response to the request for the exercise of rights, it appears that the Company did not provide a response to the request for access to the personal data of the interested party, pursuant to Article 15 of the Regulation, within the time limits set by Article 12 of the same Regulation. Specifically, to the request made by the interested party on January 9, followed up on XX, the health company provided a response with a note dated XX (prot. no. XX), following the invitation to comply issued by the Authority, therefore, 162 days after the day it received such request.

In light of all the above, it is established that the Company, as the data controller, processed the complainant's data in violation of the basic principles of processing referred to in Articles 5, paragraph 1, letter f), and 9 of the Regulation and the security obligations related to processing referred to in Article 32 of the Regulation, and also in violation of Article 15, having failed to provide a response to the request for the exercise of rights submitted by the interested party within the time limits set out in Article 12 of the Regulation (Article 12 of the Regulation in relation to Article 15 of the same Regulation).

Finally, it is believed that the conditions referred to in Article 17 of the Guarantor's Regulation No. 1/2019 are met.

#### 5. Adoption of the injunction order for the application of the administrative monetary sanction and accessory sanctions (Articles 58, paragraph 2, letter i and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The violation of Articles 5, paragraph 1, letter f), 9, 12, in relation to Article 15, and 32 of the Regulation, caused by the conduct carried out by the Company, is subject to the application of the administrative monetary sanction pursuant to Article 83, paragraphs 4 and 5 of the Regulation. It should be noted that the Guarantor, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative monetary sanction pursuant to Article 83, in addition to (other) corrective measures referred to in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case," and, in this context, "the Board (of the Guarantor) adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Guarantor's Regulation).

Guarantee No. 1/2019).

In this specific case, the Company has engaged in two distinct behaviors, which must therefore be considered separately for the purpose of quantifying the administrative sanctions to be applied. The aforementioned administrative monetary sanctions imposed, depending on the circumstances of each individual case, must be determined in amount while duly taking into account the elements provided for in Article 83, paragraph 2, of the Regulation.

#### 5.1. In this regard, considering Article 83, paragraph 3, of the Regulation, the violation of the provisions cited in paragraph 4.1 of this decision is subject to the application of the administrative monetary sanction provided for in Article 83, paragraph 5 of the Regulation.

In light of the above and, in particular, the characteristics of the processing, in relation to the type of operation (communication) and the data subject (patient), and the category of personal data affected by the violation (health data, which, by their nature, are particularly sensitive in terms of fundamental rights and freedoms), it is believed that the level of severity of the violation committed by the Company, based on the elements referred to in Article 83, paragraph 2, letters a) and g) of the Regulation, is high (see European Data Protection Board, "Guidelines 04/2022 on the calculation of administrative fines

under the GDPR” of May 23, 2023, point 60).

That said, having evaluated certain elements as a whole and, in particular, that:

- the data controller, in order to avoid the recurrence of the event that occurred, has committed to implementing measures aimed at increasing the level of security of the processing carried out and, therefore, to reduce the replicability of the event that occurred (Article 83, paragraph 2, letter f) of the Regulation);
- the Company has not been the recipient of a previous sanctioning measure in relation to relevant violations (Article 83, paragraph 2, letter e) of the Regulation);
- the conduct was due to the operator's intention to establish contact with the complainant as soon as possible, considering that her clinical situation presented profiles of particular criticality and severity (Article 83, paragraph 2, letter k) of the Regulation);

it is deemed appropriate to determine the amount of the monetary sanction provided for by Articles 83, paragraphs 4 and 5 of the Regulation, in the amount of €4,000.00 (four thousand/00) for the violation of Articles 5, paragraph 1, letter f), 9, and 32 of the same Regulation, as an administrative monetary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

5.2. The distinct conduct that led to a violation of the provision cited in paragraph 4.2 of this decision, namely Article 12 of the Regulation in relation to Article 15 of the same Regulation, entails the application of the administrative monetary sanction provided for in Article 83, paragraph 5, of the Regulation.

With specific regard to the nature and severity of the violation (Article 83, paragraph 2, letters a) and g) of the Regulation), it is believed that the level of severity of such violation committed by the Company is medium (see the aforementioned “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60). Additionally:

- the Company has responded to the data subject; even in this circumstance, it has not been the recipient of a previous sanctioning measure in relation to relevant violations (Article 83, paragraph 2, letter e) of the Regulation);
- the circumstance that the complainant shares a name with an employee of the Company (who is part of the U.O.S.D. that manages cancer screening) has mistakenly led the protocol service operators to transmit the documentation solely to the Personnel Office and not to the Office responsible for managing such requests (Article 83, paragraph 2, letter k) of the Regulation).

In light of the aforementioned elements, it is deemed appropriate to determine the amount of the monetary sanction provided for in Article 83, paragraph 5, of the Regulation in the amount of €1,000.00 (one thousand/00) for the violation of Article 12 of the Regulation, in relation to Article 15 of the same Regulation, for failing to respond to the request for the exercise of rights submitted by the data subject within the terms of Article 12 of the Regulation, as an administrative monetary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

In light of the above, the total quantification of the sanction amounts to €5,000.00 (five thousand/00).

5.3. Considering the type of personal data subject to unlawful processing (health data), the type of operation (communication), and the data subject (patient), it is also believed that pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantee No. 1/2019, the publication of this section, containing the injunction order, on the website of the Guarantee should proceed.

**ALL OF THE ABOVE CONSIDERED, THE GUARANTEE**

pursuant to Articles 57, paragraph 1, letter f) and 83 of the Regulation, notes the unlawfulness of the processing carried out by the territorial health authority of Macerata, based in Piediripa di Macerata, Via Domenico Annibali, 31 – postal code 62100 – VAT/Tax Code 02095680431, in the terms outlined in the motivation, for the violation of the provisions of Articles 5, paragraph 1, letter f), 9, 12, in relation to 15, and 32 of the Regulation, in the terms outlined in

**\*\*Motivation;\*\***

**\*\*ORDERS\*\***

pursuant to Articles 58, paragraph 2, letter i) to the same Territorial Health Authority of Macerata, to pay the sum of €5,000.00 (five thousand/00) as an administrative pecuniary sanction for the violations indicated in this provision;

**\*\*ENJOINS\*\***

therefore, the aforementioned holder, to pay the sum of €5,000.00 (five thousand/00) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of the consequent executive acts in accordance with Article 27 of Law No. 689/198. It is represented that pursuant to Article 166, paragraph 8 of the Code, the possibility for the offender to settle the dispute by paying - according to the methods indicated in the attachment - an amount equal to half of the imposed sanction within the term referred to in Article 10, paragraph 3, of Legislative Decree No. 150 of September 1, 2011, provided for the submission of the appeal as indicated below, remains unaffected.

**\*\*PROVIDES\*\***

- pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor No. 1/2019, the publication of the injunction order on the Guarantor's website;
- pursuant to Article 154-bis, paragraph 3, of the Code and Article 37 of the Regulation of the Guarantor No. 1/2019, the publication of this provision on the website of the Authority;
- pursuant to Article 17 of the Regulation of the Guarantor No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, an appeal against this provision may be made to the ordinary judicial authority, with an application filed at the ordinary court of the place identified in the same Article 10, within thirty days from the date of communication of this provision, or sixty days if the applicant resides abroad.

Rome, March 27, 2025

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei